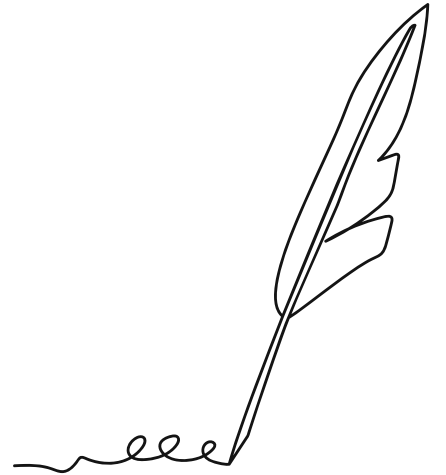


Hafta 4: Hedefi Tanıma Ve Mantık Hataları

Görev 4: Bug Hunter Başlangıç Raporu

Saniye Topal



Görev 4: Bug Hunter Başlangıç Raporu

Bölüm A : Teori ve Mimari (Research and Logic)

1.Web Anatomisi : HTTP Protokolü

200 kodu: Kullanıcı Girişinin başarılı olduğunu söyler. Saldırganlara kapının açık olduğunu ve içeri sızmak için yol olduğunu gösterir. Eğer /admin veya /config gibi yetki gerektirmesi gereken bir sayfada 200 OK alıyorsak, orada bir Eksik Yetkilendirme (Missing Authorization) zafiyeti bulunduğunu gösterir.

302 kodu: Sitenin kullanıcıyı başka bir siteye yönlendirdiğini gösterir. Pentest için önemli olan burada yönlendirmeden hemen önceki kısa sürede veri sızdırıp sızdırmadığıdır. Ve de diğer kullanıcıların başka kötü amaçlı bir siteye gönderilebilir mi diye bakar.

401 kodu: Kullanıcının geçerli kimlik doğrulamasına sahip olmadığını gösterir. Burada geçerli kullanıcı bilgilerine ulaşılmaya çalışır.

403 kodu: Giriş yapılmıştır ancak erişim yetkisi yoktur. Sızma testinde burada erişilmeye çalışılır çünkü en önemli veriler burada saklanır. Header manipülasyonu, dizin atlama , IP kısıtlaması gibi yöntemler kullanılır.

500: Sunucu burada kendi sisteminde hata oluştuğunun haberini verir. Bu sunucunun girdileri işleyemediği anlamına gelebilir. SQL injection veya kod yürütme zafiyeti gibi açıklar bulunabilir.

2.Kimlik ve Yetki : Sen kimsin?

Cookie, session, ve token: Kimlik doğrulama gerçekleştikten sonra sunucu, istemciye bir tanımlayıcı iletir. Cookie , HTTP başlıkları Set-Cookie aracılığıyla sunucu tarafından tarayıcıya gönderilen ve tarayıcının yerel depolama alanında saklanan küçük veri paketidir. Session (Oturum): Sunucu taraflı (Server-side) bir depolama mekanizmasıdır. Kullanıcı doğrulandığında, sunucu belleğinde veya bir veri tabanında bir kayıt açılır. Bu kayda erişmek için oluşturulan benzersiz anahtar istemciye bir Cookie içinde gönderilir. Token , istemci taraflı (Client-side) ve genellikle stateless olan bir kimlik doğrulama yöntemidir. Sunucu, kullanıcı bilgilerini ve yetkilerini içeren dijital imzalı bir veri bloğu oluşturur. Sunucu bu bilgiyi her istekte istemciden gelen Token'ın imzasını algoritma ve secret keyle doğrular. Sayafayı her yenilediğinizde tarayıcı , HTTP isteğini header kısmına ekler. Session tabanlıysa Cookie başlığı altında sakladığı oturum anahtarını sunucuya iletir. Token tabanlıysa tarayıcı (genelde JavaScript aracılığıyla), isteğin header kısmına Authorization: Bearer <token_verisi> bilgisini ekler. Sunucu bu Token ı alır, imzasının geçerliliğini ve süresini (expiration) kontrol eder. Veri doğruysa isteği işler.

Authentication vs Authorization: Authentication ve Authorization kavramları erişim kontrol mekanizmasının 2 farklı katmanıdır. Authentication kimlik doğrulama katmanıdır. Login işlemi burada gerçekleşir. Kullanıcı kimlik bilgilerini yani kullanıcı bilgilerini girer. Sunucu bu verileri veri tabanındaki hash lenmiş verilerle karşılaştırır. Eşleşme varsa kimlik doğrulama gerçekleşir. Authorization ,yetki katmanıdır. Kimliği doğrulanmış bir kullanıcının neler yapabileceğini ve hangi verilere ulaşabileceğini belirler. IDOR, yetkilendirme zaafiyetidir.

3.Zaafiyet Mimarisi: IDOR

IDOR zaafiyeti kullanıcının kimlik doğrulamasını başarılı bir şekilde gerçekleştirdikten sonra sunucunun kullanıcı yetkisini, erişim yapabileceği verileri ve neler yapabileceğini kontrol etmemesidir. Yani yetkilendirme aşaması sağlıklı bir şekilde gerçekleşmez. Kırık erişim kontrolü açığı vardır.

Bölüm B: Saha Eğitimi (TryHackMe ve Dorking)

1. İnternetin Röntgeni:

User-Agent ve Host : User-Agent isteği yapan web tarayıcısını veya istemci uygulamasını sunucuya bildirir. Bu da sunucunun yazılıma göre yanıt vermesini sağlar. Host başlığı ise bazı serverlar birden fazla web sitesine ev sahibi olabilirler host hedef sunucunun alan adının ve port un belirlendiği kısımdır.

2. Google Dorking ;3 farklı dork sorgusu:

site:ankasec.co ext:pdf bu sorgu ankasec.co sitesindeki halka açık olaral bırakılan belgeleri görülmesini sağlar.

site:ankasec.co inurl:admin bu sorgu admin girişi var mı diye sorgular gizli paneller bulunmaya çalışılır.

site:ankasec.co ext:sql bu sorgu sql veri tabanı yedeklerini arar. Bu dosyalar çok hassa veriler içerebilir.

